

03 — API Contract

REST endpoints, validation, authorization, transactions and rate limits

CampusFlow • Production Specification • v1.0 • October 2026

1. API Contract

Base path: /api.

Transport: HTTPS.

Format: JSON.

Protected endpoints require authenticated server-side session.

```
{"success":false,"error":{"code":"EVENT_REGISTRATION_CLOSED","message":"Registration for this event is closed."},"requestId":"req..."}
```

2. Endpoints

POST /api/auth/login — public — email/password — 200 user + mustChangePassword + secure cookie.

POST /api/auth/logout — auth — 204.

GET /api/me — auth — current user.

GET /api/dashboard — auth — prioritySummary, deadlines, notices, events, unreadCount.

GET /api/notices — auth — search/filter/pagination.

POST /api/notices — faculty/admin — create draft.

PATCH /api/notices/:id — faculty/admin — edit.

POST /api/notices/:id/publish — faculty/admin — publish and notify.

GET /api/notices/:id — audience-authorized detail.

GET /api/events — auth — list/filter.

POST /api/events — faculty/admin — create.

PATCH /api/events/:id — faculty/admin — edit.

GET /api/events/:id — auth — detail.

POST /api/events/:id/register — auth — register.

DELETE /api/events/:id/register — auth — cancel.

GET /api/events/:id/registrations — admin — list.

GET /api/deadlines?filter=upcoming|overdue|all — auth.

GET /api/notifications — auth.

PATCH /api/notifications/:id/read — auth.

GET /api/search?q= — auth.

GET /api/admin/audit-logs — admin.

GET /api/admin/users — admin.

PATCH /api/admin/users/:id/role — admin.

POST /api/admin/users/import — admin CSV import.

GET /health — infrastructure health.

3. Login Contract

College email must end with @moderncoe.edu.in.

Normalize by removing whitespace and lowercasing.

Password minimum 8 characters.

Return user + mustChangePassword and set secure httpOnly cookie.

4. Event Registration Transaction

- Authenticate user.
- Lock/check event inside transaction.
- Verify event is published.
- Verify registration deadline.
- Verify eligibility.
- Check duplicate registration.
- Check capacity transactionally.
- Insert registration.
- Create confirmation notification.
- Commit.

Return 409 ALREADY_REGISTERED, 409 EVENT_FULL, or 422 REGISTRATION_CLOSED.

5. Rate Limits

Login: 5/min per IP + normalized email.

Notice publish: 20/min per actor.

Event registration: 10/min per user.

Search: reasonable authenticated burst limit.

6. HTTP Semantics

200 success; 201 created; 204 no content; 400 bad request; 401 unauthenticated; 403 unauthorized; 404 not found; 409 conflict; 422 validation failure; 429 rate limit; 500 unexpected error.